

NIS2 / DORA Vendor Clause Set

ComplianceDocs - v1.0, August 2026 - Not legal advice - have counsel review before use.

About this document

Regulated clients (and their auditors and insurers) increasingly treat the company that runs their website as part of their supply chain. Under **NIS2**, essential and important entities must manage supply-chain security; under **DORA Art. 28–30**, financial entities must contractually govern ICT third-party providers.

This clause set gives you ready-to-use contract language to answer regulated client demands before they ask.

1. Contract & governance clauses

1.1 Service description

The Vendor shall perform the following services for each Site: software updates (core, plugins, themes), security patch deployment, automated daily backups with off-site storage, uptime monitoring, and incident response as defined in the Security appendix. A current scope-of-service matrix per Site is maintained in the Change Log and updated at each Material Change.

Purpose: Prevents scope creep and gives the client - and their auditor - a fixed reference for what is included.

1.2 Security measures

The Vendor maintains and documents Technical and Organisational Measures (TOMs) including but not limited to: access control based on least-privilege principle, encrypted credential storage (AES-256 or equivalent), multi-factor authentication for all administrative access, and regular vulnerability scanning of the hosting environment. The current TOMs register is attached as Appendix A.

Purpose: Regulated clients will not sign without explicit security commitments. "We take security seriously" is not enough - this clause gives them the contractual language they need.

1.3 Audit / evidence right

The Client may request, at reasonable notice (not less than 10 business days), documentation of performed work including Change Log extracts, backup test records, and access reviews. The Vendor shall provide such documentation within 5 business days of the request. The Client's external auditors may, upon signing a NDA, review the Vendor's TOMs register once per calendar year.

Purpose: NIS2 Art. 21(2) and DORA Art. 30(1) both require the ability to audit third-party providers. This clause satisfies that contractual obligation.

1.4 Incident notification

The Vendor shall notify the Client of any Security Incident affecting a Site within 24 hours of confirmation, by telephone to [Client contact] followed by written notification by email within 4 hours. The notification shall include: time of detection, nature and scope of the incident, affected systems, measures taken, and an estimated timeline for resolution.

Purpose: Regulated entities must report incidents to their competent authority within specific timeframes (NIS2: 24h early warning, DORA: as per Art. 19 classification). The Vendor's notification is the Client's starting signal for that clock.

1.5 Subcontracting

The Vendor may engage Subcontractors (hosting provider, backup storage, monitoring tooling) provided that each Subcontractor is bound by obligations equivalent to those in this Agreement. A current list of Subcontractors is maintained in Appendix B. The Vendor shall notify the Client of any proposed change to Subcontractors at least 30 days in advance.

Purpose: Chain liability runs through subcontractors. Regulated entities must know and approve every link in the chain.

1.6 Data location

All Client Data, including backups, shall be stored within the European Economic Area (EEA). The primary hosting location is [Hetzner Finland / Germany / OVH France]. No data shall be transferred to a third country without the Client's prior written consent and an adequate transfer mechanism under Art. 44–49 GDPR.

Purpose: EU data sovereignty is a baseline requirement under both NIS2 and GDPR. "Cloud" without jurisdiction is a red flag for compliance teams.

1.7 Termination & exit

Upon termination of this Agreement for any reason, the Vendor shall within 14 days: (a) deliver a complete backup of each Site, (b) export the full Change Log for each Site, (c) return or securely delete all Client Data in accordance with the Client's instructions, and (d) provide credentials and access URLs to the Client or its nominated provider.

Purpose: Lock-in is a compliance risk. A regulated entity must be able to change vendor without losing evidence of past due diligence.

1.8 Liability cap

The Vendor's aggregate liability under this Agreement shall not exceed the total fees paid by the Client in the 12 months preceding the event giving rise to the claim. Neither party excludes liability for (a) death or personal injury, (b) fraud or wilful misconduct, (c) breach of data protection obligations under GDPR, or (d) any liability that cannot be excluded by applicable law.

Purpose: A cap that is realistic for both sides - high enough for the client's insurer to accept, low enough for the vendor to operate. The carve-outs ensure GDPR breach liability is not capped away.

2. Evidence you must be able to produce

- **Change log per site:** every core/plugin/theme update with before/after versions, timestamp and operator identity
- **Backup records:** schedule, retention period, proof of periodic restore tests - not just "backups are taken"
- **Access inventory:** who has admin access to which sites, reviewed periodically
- **Patch policy:** agreed maximum time from security release to deployment
- **DPA:** a signed data-processing agreement if personal data is involved (contact forms, analytics, webshop orders)

3. Questions your regulated client may ask

- "Where exactly are our backups stored, and under whose jurisdiction?"

- "Show me what was changed on our site last quarter, by whom."
 - "When was the last restore test, and can I see the record?"
 - "Do you use subcontractors or AI automation? Who is accountable?"
 - "What happens to our data if we terminate the agreement?"
-

Disclaimer

This clause set is a template and reference aid, not a legal document. It does not constitute legal advice. NIS2 and DORA implementation varies by EU member state. Have the completed clauses reviewed by qualified legal counsel before incorporating into any contract, especially for regulated entities in multiple jurisdictions.

ComplianceDocs · v1.0 · Professional template with guidance comments - not legal advice.